

PolicyHub

UX Specification — Admin Surface

Version 1.0 · March 2026 · Supplement to main UX Spec (screens 01–08)

This document covers the six admin screens (09–14) of PolicyHub, supplementing the main UX Specification which covered the authoring surface (screens 01–04) and reader surface (screens 05–08). The admin surface is accessible only to users with the `policy:admin` role.

Cross-cutting admin design decisions

- Slide-over for create/edit — all admin create and edit actions use a right-side slide-over panel, keeping the table visible and in context.
- Inline confirm for destructive actions — archive, deactivate, and delete show an inline confirmation strip (not a modal) requiring a second deliberate click.
- Table-first layout — all admin screens are table-based with filter controls above. No card grids.
- Append-only audit trail — the audit log has no edit or delete controls anywhere in the admin surface.
- IdP sync philosophy — roles and group memberships are owned by the IdP. The admin surface provides overrides and inspection, not a replacement for IdP management.

09 — Users

Role: Policy Admin · Trigger: Admin → Users

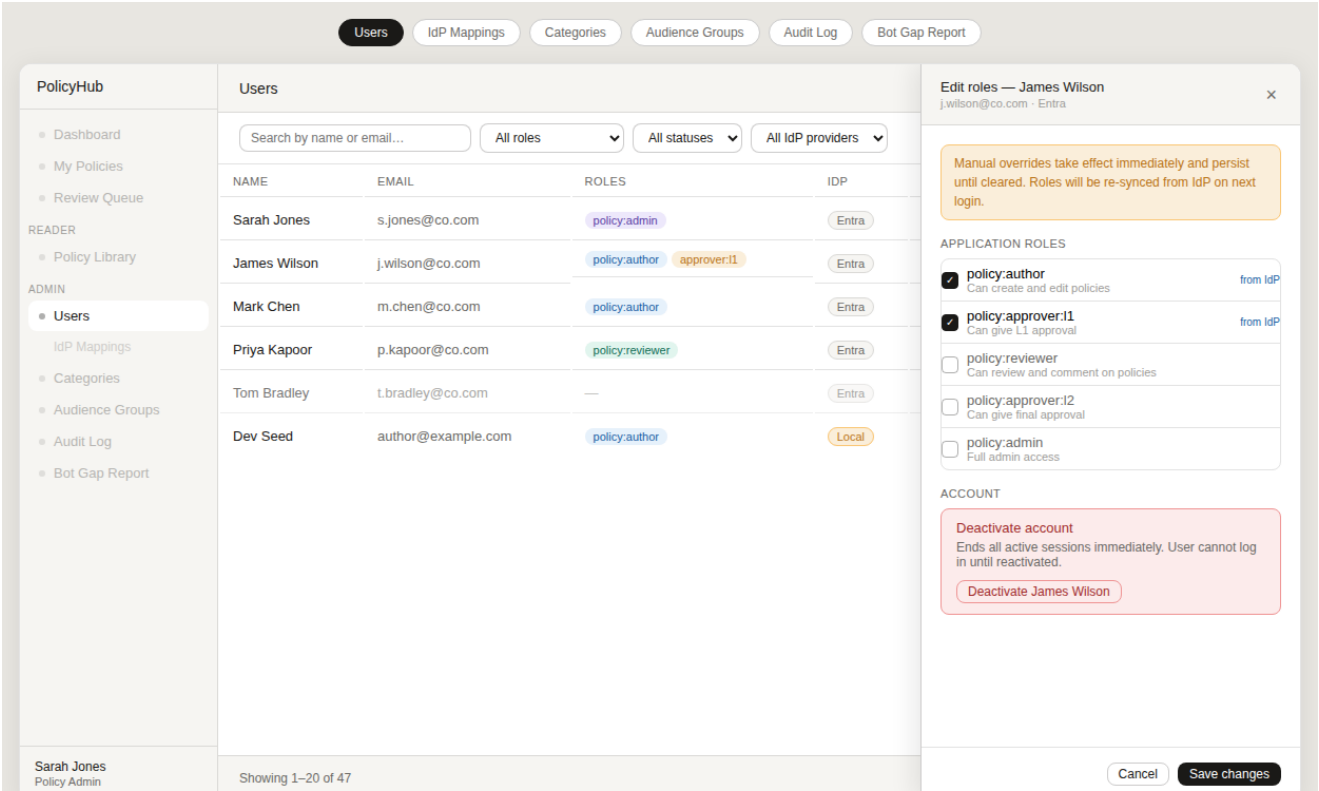


Fig. 09 — Users

The primary user management surface. A filterable table shows all users with their roles (sourced from IdP at last login), IdP provider, last login date, and active status. Local auth users (seeded for dev/staging) are flagged with an amber "Local" badge. Clicking "Edit roles" opens a slide-over panel — the pattern used consistently across admin create/edit actions — showing the full role list with IdP-sourced roles indicated. Deactivation is a destructive action shown in the slide-over with an inline confirmation, not a modal, consistent with the Categories archive pattern.

Design decisions

- Slide-over for edit/create — keeps the table visible and in context while editing a single user.
- IdP-sourced roles are labelled "from IdP" and remain checked but can be overridden. The override note explains re-sync behaviour on next login.
- Deactivation confirm is inline within the slide-over, not a separate modal — one less context switch.
- Local auth users are visually flagged — admin can identify and audit seeded dev accounts in staging.
- Pagination at 20 rows with CSV export — bulk management is handled via IdP group mappings, not this table.

10 — IdP Group → Role Mappings

Role: Policy Admin · Trigger: Admin → Users → IdP Mappings (sub-item)

Users

IdP Mappings

Categories

Audience Groups

Audit Log

Bot Gap Report

PolicyHub

Dashboard

My Policies

Review Queue

READER

Policy Library

ADMIN

Users

IdP Mappings

Categories

Audience Groups

Audit Log

Bot Gap Report

Sarah Jones

Policy Admin

IdP Group → Role Mappings

+ Add mapping

How this works: When a user logs in via Entra, PolicyHub reads their group IDs from the ID token and assigns any mapped roles. Changes here take effect on the user's next login.

IDP GROUP ID	GROUP NAME (REFERENCE ONLY)	MAPPED ROLE	USERS AFFECTED	ADDED	
a1b2c3d4-0001-0001-0001-aabbccdd0001	PH-Policy-Admins	policy:admin	3 users	14 Jan 2025	Remove
a1b2c3d4-0002-0002-0002-aabbccdd0002	PH-Policy-Authors	policy:author	18 users	14 Jan 2025	Remove
a1b2c3d4-0003-0003-0003-aabbccdd0003	PH-Policy-Reviewers	policy:reviewer	12 users	14 Jan 2025	Remove
a1b2c3d4-0004-0004-0004-aabbccdd0004	PH-L1-Approvers	policy:approver:1	7 users	14 Jan 2025	Remove
a1b2c3d4-0005-0005-0005-aabbccdd0005	PH-Policy-Committee	policy:approver:2	5 users	14 Jan 2025	Remove

Group Object IDs are found in Azure Portal → Entra ID → Groups → [group] → Overview. See the Entra setup guide for details.

Download mapping CSV

Fig. 10 — IdP Group → Role Mappings

The IdP group-to-role mapping table is the primary governance tool — it defines which Entra group memberships map to which PolicyHub roles, applied automatically at each login. The screen is deliberately simple: a flat table with one mapping per row, add and remove only. No inline editing — adding a mapping is atomic (group ID + role, one action). The "users affected" count gives admin confidence that a group ID is correct before committing. A footer note directs admins to the Entra setup guide for finding group Object IDs.

Design decisions

- Flat add/remove table only — no inline editing. A misconfigured mapping is removed and re-added, never patched in place.
- "Users affected" count is live from the database — it confirms the group ID maps to real users before saving.
- Group display name is a reference-only free-text field — PolicyHub never queries Entra for group names.
- Positioned as a sub-item under Users in the sidebar — related but secondary to the user table itself.

11 — Categories

Role: Policy Admin · Trigger: Admin → Categories

UsersIdP MappingsCategoriesAudience GroupsAudit LogBot Gap Report

PolicyHub

Dashboard

My Policies

Review Queue

READER

Policy Library

ADMIN

Users

IdP Mappings

Categories

Audience Groups

Audit Log

Bot Gap Report

Sarah Jones

Policy Admin

Categories

5 categories + New category

CATEGORY	POLICIES	DEFAULT L1 APPROVER	DEFAULT L2 APPROVER	STATUS	
Finance Expense, travel, and financial controls	5 published	Sarah Jones	Policy Committee	Active	EditArchive
HR Employment, leave, and people policies	8 published	James Wilson	Policy Committee	Active	EditArchive
IT Technology use, security, and data handling	6 published	Priya Kapoor	Policy Committee	Active	EditArchive
Legal Compliance, contracts, and legal obligations	3 published	Sarah Jones	Policy Committee	Active	EditArchive
Operations (archived) Merged into Finance — Jan 2024	0 active	—	—	Archived	Restore

Archive Finance? New policies cannot be created in this category. Existing policies are unaffected.

CancelArchive

Fig. 11 — Categories

Category management covers the taxonomy that policies are filed under and the default approval chains that apply when a policy in a category is submitted. The default L2 approver is particularly important — it is shown read-only on the Submit screen and drives which committee reviews final approval. Archiving a category prevents new policies being created in it but leaves existing policies untouched. The inline confirmation pattern (shown at the bottom of the screen) avoids a modal while still requiring a deliberate two-step action for destructive operations.

Design decisions

- Default L2 approver is set at category level, not at policy level — this enforces governance structure without relying on authors knowing which committee applies.
- Archive not delete — policy records are never orphaned. Archived categories still appear in version history for historical policies.
- Inline confirmation strip at screen bottom — destructive action is visible without obscuring the table row.
- Archived categories shown with reduced opacity and a Restore action — reversible without data loss.

12 — Audience Groups

Role: Policy Admin · Trigger: Admin → Audience Groups

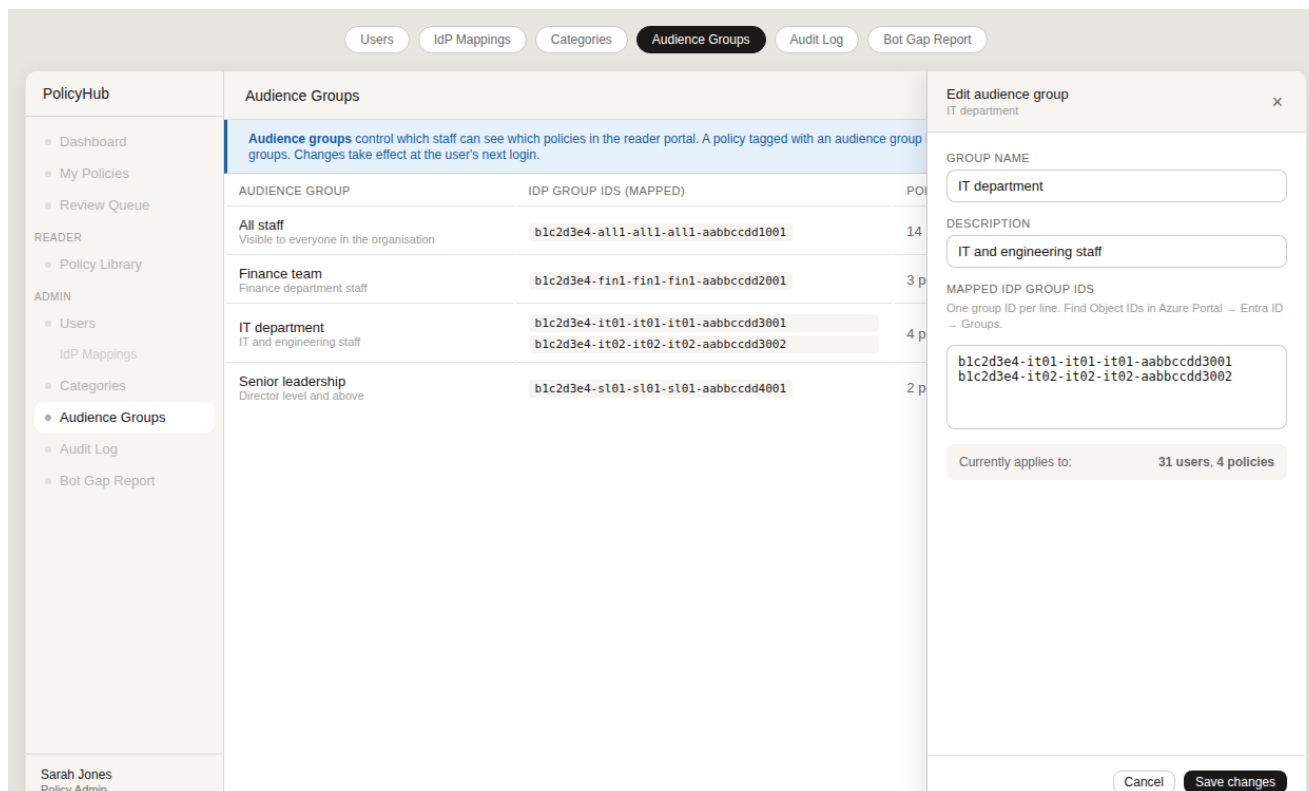


Fig. 12 — Audience Groups

Audience groups are the reader portal RBAC mechanism. Each group maps to one or more Entra group IDs; users whose token contains any of those group IDs can see policies tagged with that audience. The slide-over edit pattern is used here, with a textarea for entering multiple group IDs (one per line) — reflecting the multi-group mapping case (e.g. IT department has two Entra groups). The "currently applies to" summary at the bottom of the slide-over gives admin confidence in the scope of a change before saving.

Design decisions

- Multi-line textarea for group IDs — simpler than a dynamic tag input for what is typically 1–3 IDs, and avoids ambiguity about delimiters.
- "Currently applies to N users, N policies" summary in the slide-over — makes the blast radius of a change visible before saving.
- Delete is available only when the audience group has zero associated policies — prevents accidentally restricting access to published policies.
- The "All staff" group cannot be deleted — enforced by the UI (no Delete button on that row).

13 — Audit Log

Role: Policy Admin / Compliance Officer · Trigger: Admin → Audit Log

Users

IdP Mappings

Categories

Audience Groups

Audit Log

Bot Gap Report

PolicyHub

Dashboard

My Policies

Review Queue

READER

Policy Library

ADMIN

Users

IdP Mappings

Categories

Audience Groups

Audit Log

Bot Gap Report

Sarah Jones

Policy Admin

Audit Log

Export filtered CSV

Date from

Date to

All users

All policies

All actions

Apply

1,284 events (filtered)

TIMESTAMP	ACTOR	ACTION	POLICY / RESOURCE	DETAIL
2025-01-15 14:32:07	James Wilson	policy_submitted	Expense Policy 2025	Submitted for review · reviewer: Sarah Jones
2025-01-15 14:30:01	James Wilson	policy_saved	Expense Policy 2025	Manual save · commit abc1234
2025-01-15 11:04:22	Sarah Jones	policy_approved	IT Acceptable Use Policy	L1 approval granted
2025-01-15 10:58:14	Sarah Jones	comment_added	IT Acceptable Use Policy	"BYOD clause looks good. Minor wording nit on §3."
2025-01-15 09:14:33	Sarah Jones	login	—	SSO via Entra · IP 10.0.1.42
2025-01-14 16:45:11	System	review_reminder	Data Classification Policy	90-day reminder sent to Mark Chen
2025-01-14 15:21:08	Sarah Jones	role_changed	User: James Wilson	Manual override: added policy:approver:l1
2025-01-14 11:00:00	System	policy_published	Remote Working Policy	Published v1.8 · commit def5678 · PDF generated

Showing 1–20 of 1,284

Prev

1

2

3

...

65

Next

Fig. 13 — Audit Log

The audit log provides a complete, filterable, append-only record of all significant system events. Filters across date range, actor, policy, and action type can be combined; the filtered result is exportable to CSV. Action codes use the same naming convention as the audit_logs database table — what you see in the UI is exactly what is in the database, making log correlation straightforward. Policy and user resources are linked for quick navigation. The System actor is used for automated events (scheduled jobs, publishing pipeline).

- Design decisions
- Action codes shown as monospaced labels matching the database values — no translation layer that could diverge.
 - "Export filtered CSV" applies the current filter state — admins get exactly the data they are looking at, not a full dump.
 - System actor surfaced explicitly — compliance officers need to distinguish automated from human actions.
 - Append-only confirmed by UI: no edit or delete controls anywhere on the screen.
 - Pagination with large page count visible — log can be long; deep-linking to a specific page is important for sharing findings.

14 — Bot Gap Report

Role: Policy Admin · Trigger: Admin → Bot Gap Report

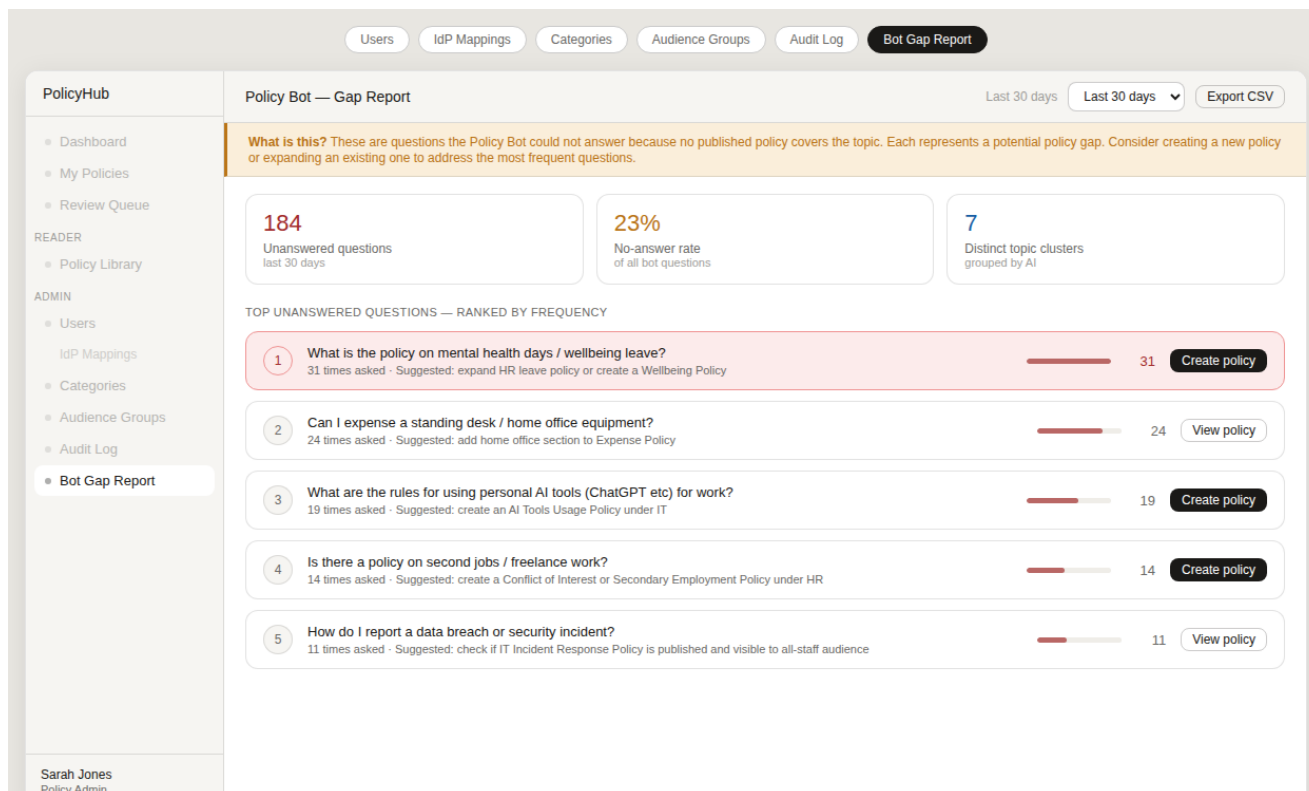


Fig. 14 — Bot Gap Report

The gap report surfaces questions the policy bot could not answer — the most actionable signal for identifying missing policies. Three summary stats give the 30-day picture at a glance (absolute count, no-answer rate, distinct topic clusters). The ranked list shows the actual question text (anonymised — no user attribution), frequency, a visual frequency bar, and an AI-generated suggestion for which policy to create or extend. "Create policy" jumps directly to the new policy wizard pre-filled with the suggested category. "View policy" links to an existing policy that may need expanding.

Design decisions

- Question text shown verbatim (within 140 chars) — paraphrasing loses the signal about how staff actually phrase questions.
- No user attribution on questions — privacy preserved by design; volume matters, not who asked.
- "Create policy" directly launches the wizard — reduces friction from insight to action.
- AI-generated suggestions are labelled as suggestions, not instructions — admin makes the final call.
- Time range selector (30/90 days/all time) — allows trending analysis without separate tooling.